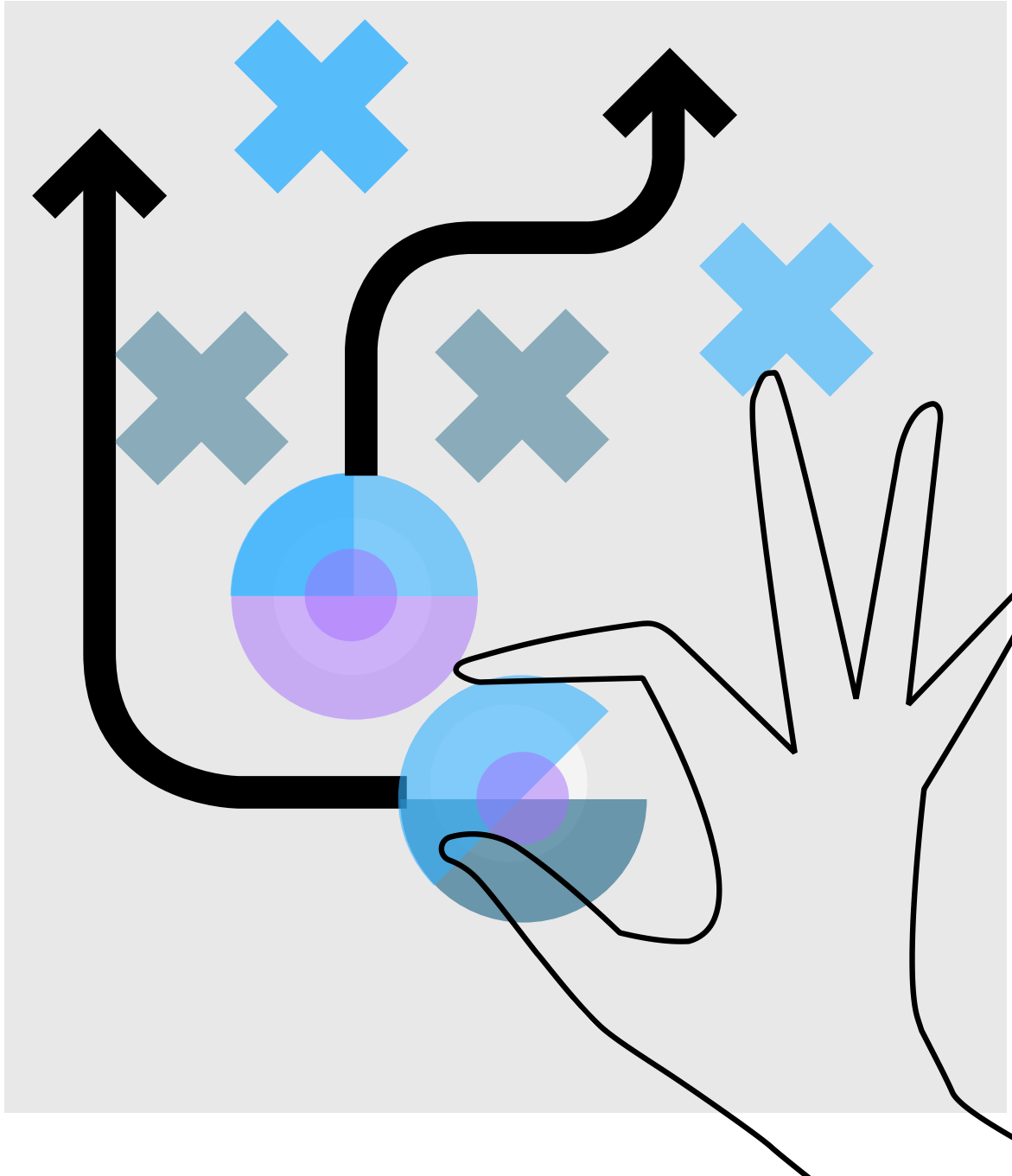
遠東金士頓

SuccessFactors Project

SAP BTP的安全架構與身份管理機制

IBM Consulting, Talent Transformation

2026.07.14



講師

課程表		課程內容備註
第一堂	預計授課日期：yyyymmdd	
	課程：BTP架構與核心概念 . BTP Global Account / Subaccount . Region / Environment . Entitlement . Service Plan . Multi-cloud architecture (AWS/Azure/GCP)	1. BTP是甚麼(Platform定位) 2. BTP四大能力 3. BTP架構 4. Account Model 概念介紹 5. BTP環境介紹 6. Extension Strategy
	熟悉 BTP Cockpit 畫面布局	
	學習材料、網站閱讀	
第二堂	預計授課日期：yyyymmdd	
	課程：BTP Account Model . Global Account . Directory . Subaccount . Quota/Entitlement	1. BTP帳號層級結構 2. 資源如何分配 3. 專案與系統如何隔離 4. 權限與管理方式
	建立Subaccount，分配Entitlement	
	學習材料、網站閱讀	
第三堂	預計授課日期：yyyymmdd	
	課程：BTP Environment . Cloud Foundry . Kyma . ABAP Environment . Neo(legacy)	1. BTP的Runtime Environment概念與架構 2. 各種Environment的用途與適用場景說明
	建立Cloud Foundry environment Org/Space	
	學習材料、網站閱讀	
第四堂	預計授課日期：yyyymmdd	
	課程：BTP Security . Identity Provider . Trust configuration . Role Collection . XSUAA	1. 介紹SAP BTP的安全架構與身份管理機制 2. 了解如何在雲端環境中管理使用者與權限
	建立 Role collection / SSO Login	
	學習材料、網站閱讀	
第五堂	預計授課日期：yyyymmdd	
	課程：BTP Connectivity . Destination service . Connectivity service . Cloud Connector	介紹 SAP BTP 的系統連線架構與技術機制，說明如何安全地讓 BTP 應用程式存取： . On-Premise SA統 . Cloud application . 外部 API
	建立Destination / 連接 On-Premise System	
	學習材料、網站閱讀	
第六堂	預計授課日期：yyyymmdd	
	課程：BTP Service Lifecycle . Service instance . Service binding . Service key	介紹 BTP 服務的生命週期管理（Service Lifecycle），說明如何： . 啟用服務 . 建立 Service Instance . 將服務綁定到應用程式 . 管理服務資源
	建立Service instance	
	學習材料、網站閱讀	

Topic

1. SAP BTP 安全架構的核心組件
2. 身份管理機制 (Identity Access Management, IAM)
3. 權限控管與授權模型 (RBAC)
4. 關鍵安全組件解析 (Deep Dive)
5. 安全最佳實踐 (Best Practices)
6. Q&A

1. SAP BTP 安全架構的核心組件

核心概念：共享責任模型 (Shared Responsibility Model)

- **SAP 的責任**：負責基礎設施、物理資料中心、底層網路與虛擬化層的安全。
- **客戶的責任**：負責應用程式開發、資料治理、身份驗證與權限配置。

核心安全:

- **Multi-Tenancy Isolation**：BTP 以Global Account 與Subaccount為組織核心，不同租戶與子帳戶之間不論在計算資源、網路或資料存取上均完全隔離。
- **Multi-Cloud Environments**：支持 Cloud Foundry、Kyma (Kubernetes) 和 ABAP 環境，所有環境內的運行時 (Runtime) 與服務實例均透過一致的安全原則進行容器化隔離。
- **Data Protection**：不論是傳輸中 (In-Transit) 或儲存中 (At-Rest) 的資料，皆採用高強度加密演算法（如 AES-256、TLS 1.2+），並支援客戶自行管理金鑰 (CMK)。 * Customer Managed Key 雲端服務或軟體平台（如 AWS MS Google Cloud 等）將資料加密金鑰的完全控制權與管理責任交給客戶的一種安全機制。
- **SAP BTP Connectivity**：透過 Cloud Connector 建立雲端與地端（On-Premise）的加密安全通道
  - 採用**逆向代理 (Reverse Invoke)** 技術，不需在地端防火牆開啟任何進站通訊埠 (Inbound Port)，即可建立安全的 TLS 加密通道。
- **Credential Store**：安全儲存與管理密碼、金鑰及憑證，避免程式碼硬編碼
- **Audit Log Service**：全面記錄系統存取與變更日誌，滿足企業合規性審計需求

2. 身份管理機制 (Identity Access Management, IAM)

SAP BTP 將使用者明確區分為「平台使用者」與「業務使用者」，並實施集中化的身份與存取管控：

1. 使用者類型區分

- **平台使用者 (Platform Users)：主要是開發人員、系統管理員與運維人員，負責管理 BTP 駕駛艙 (Cockpit)、部署應用程式與配置服務。**
- **業務使用者 (Business Users)：指使用部署在 BTP 上的企業應用程式（例如自建的 Fiori App、Extension 或 SaaS 服務）的終端客端。**

2. 身分驗證核心：SAP Cloud Identity Services

SAP 建議並預設使用 SAP Cloud Identity Services 作為中央身份管理節點，其由兩大模組組成：

- **Identity Authentication Service (IAS)：負責單一登入 (SSO)、多重身份驗證 (MFA)、密碼原則與自訂登入介面。**
- **Identity Directory (IdD)：集中儲存使用者設定檔與組群資訊，作為單一事實來源。**

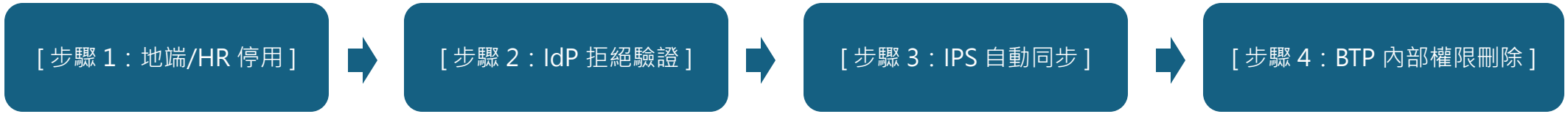
* **MFA**（Multi-Factor Authentication）**多重要素驗證**或**多因子認證**
** **TOTP**（Time-based One-Time Password) **時間型一次性密碼**

2. 身份管理機制 (Identity Access Management, IAM)

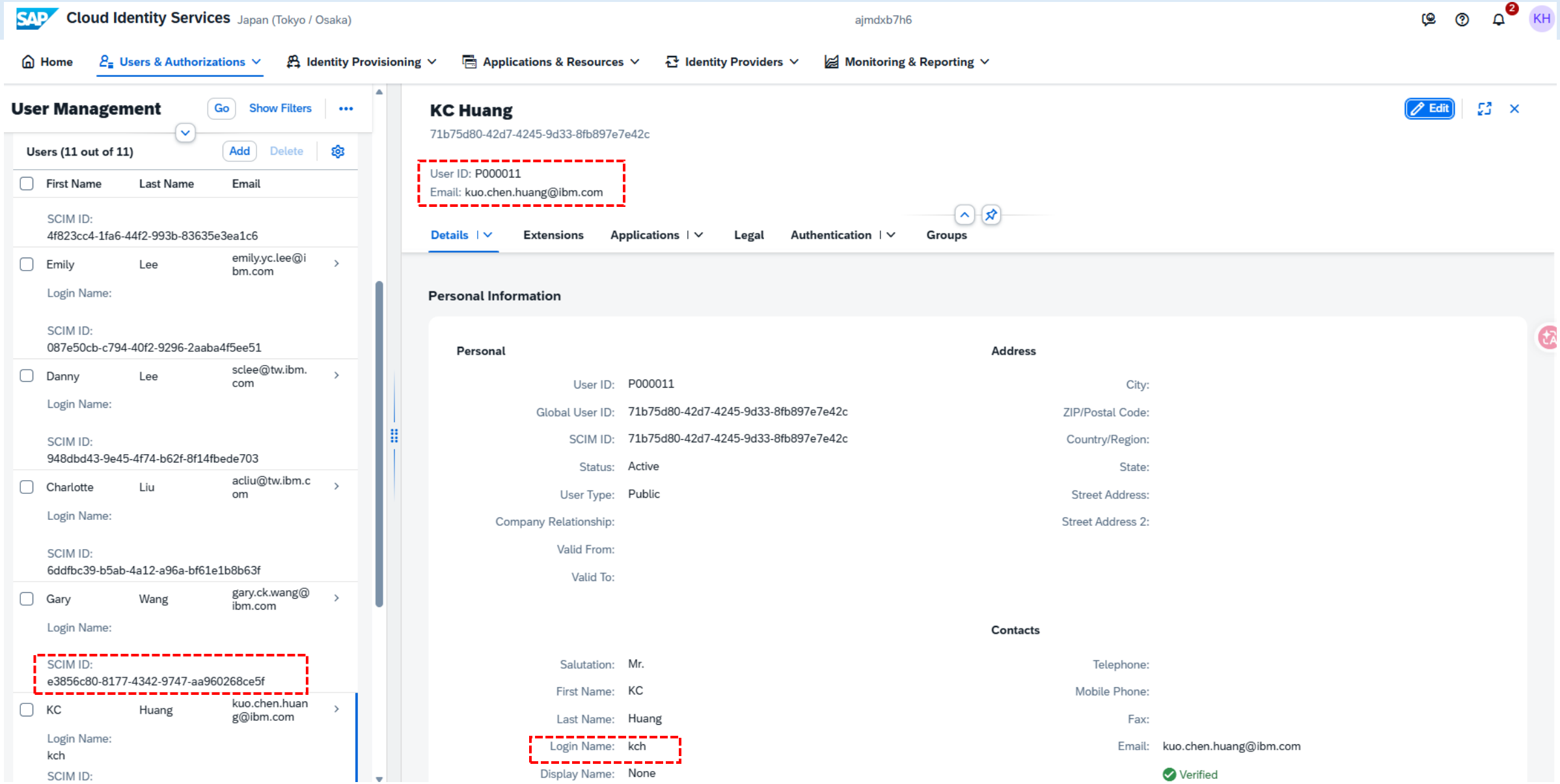
3. 企業身分提供者聯合 (IdP Federation)

雖然 BTP 提供預設的 SAP ID 服務，但企業通常會透過開源標準（**SAML 2.0** 或 **OpenID Connect**），將 SAP Cloud Identity Services 連結至企業現有的 IdP（如 Microsoft Entra ID、Okta 或 Ping Identity）。這能達到：

- **單一登入 (SSO)：員工不需記憶多套密碼即可無縫存取 SAP 雲端服務。**
- **生命周期同步：當員工離職並於企業內部停用帳戶時，其 BTP 存取權限會同步失效。**

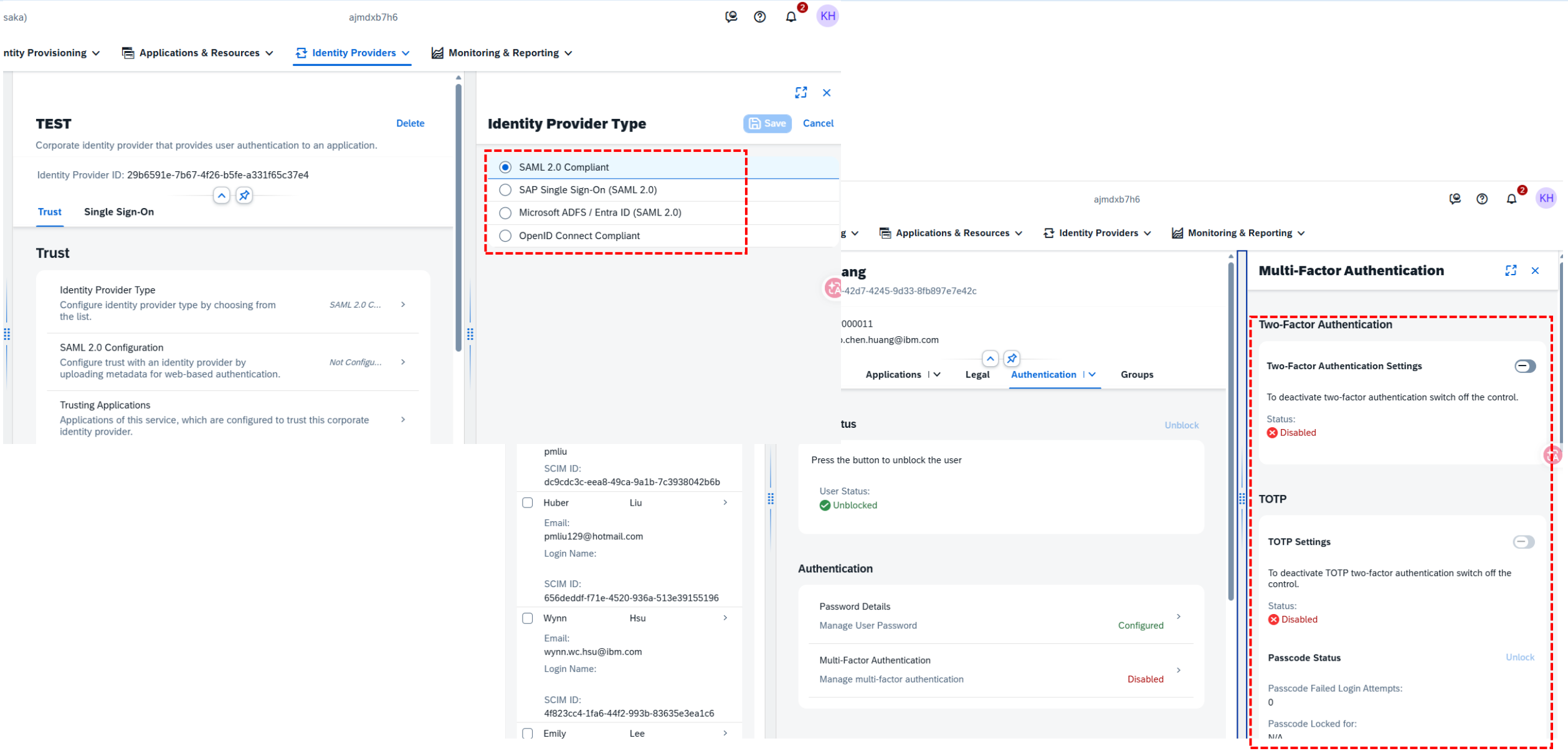


2. 身份管理機制 (Identity Access Management, IAM)

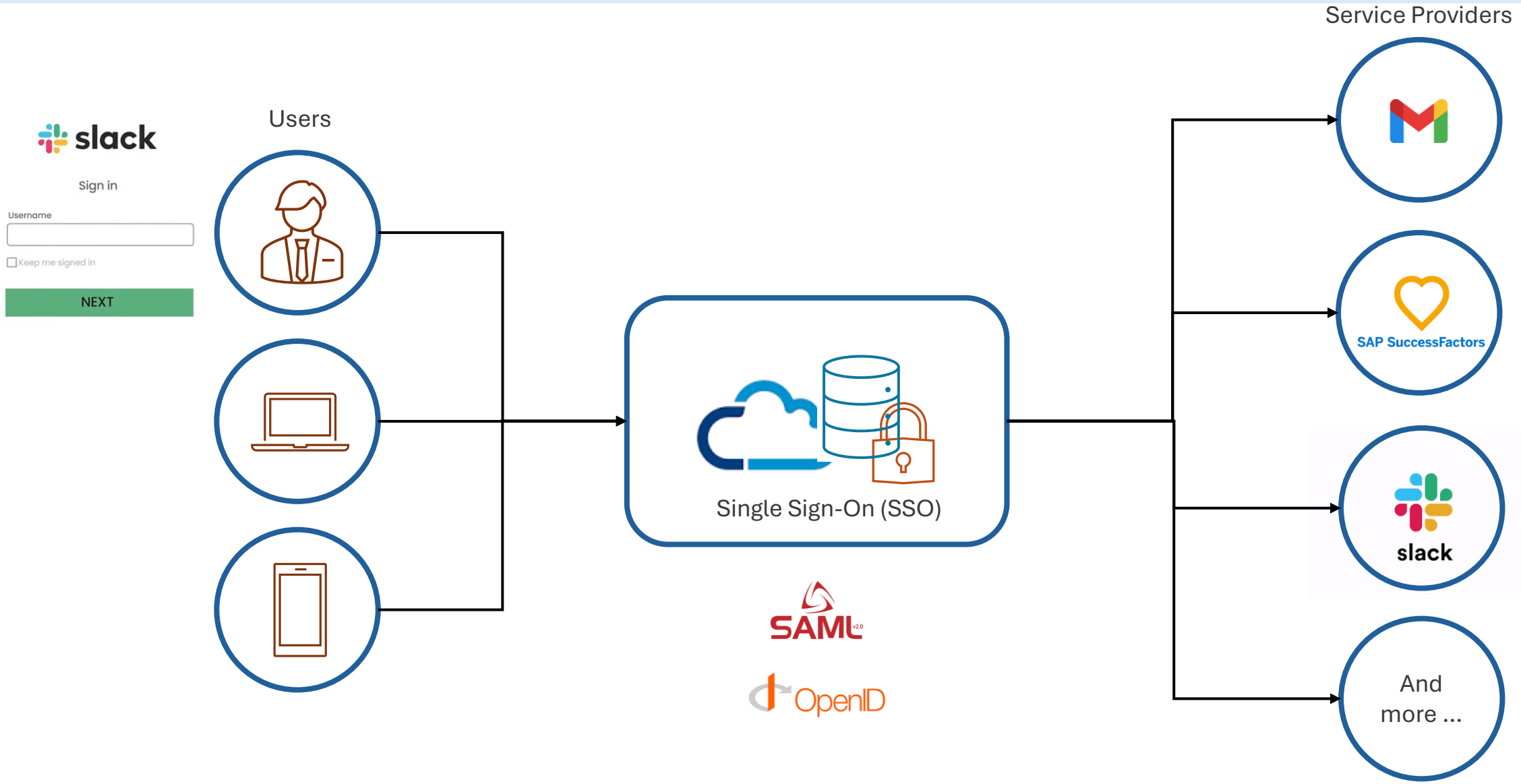


* SCIM (System for Cross-domain Identity Management) 是一種開放的國際標準通訊協定。它的主要功能是「**自動化帳號同步（Provisioning）**」。

2. 身份管理機制 (Identity Access Management, IAM)

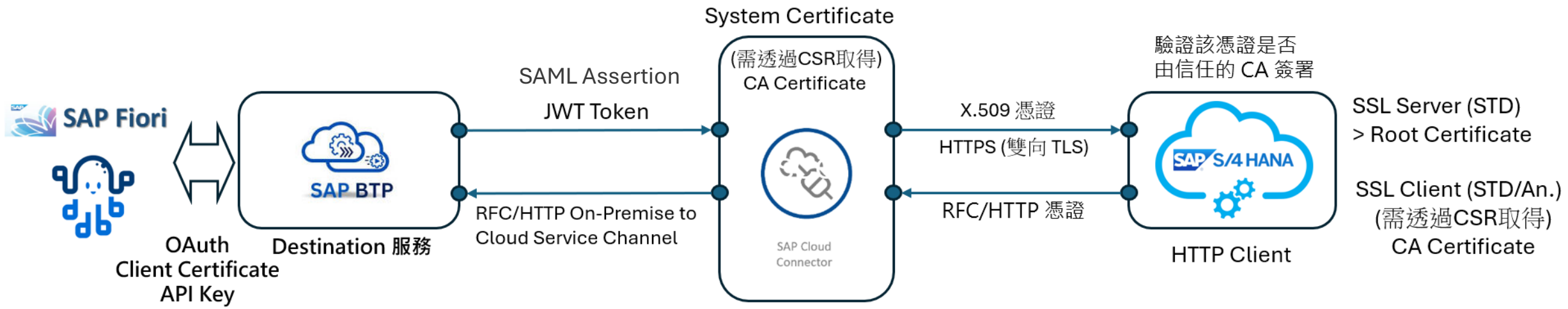


2. 身份管理機制 (Identity Access Management, IAM)

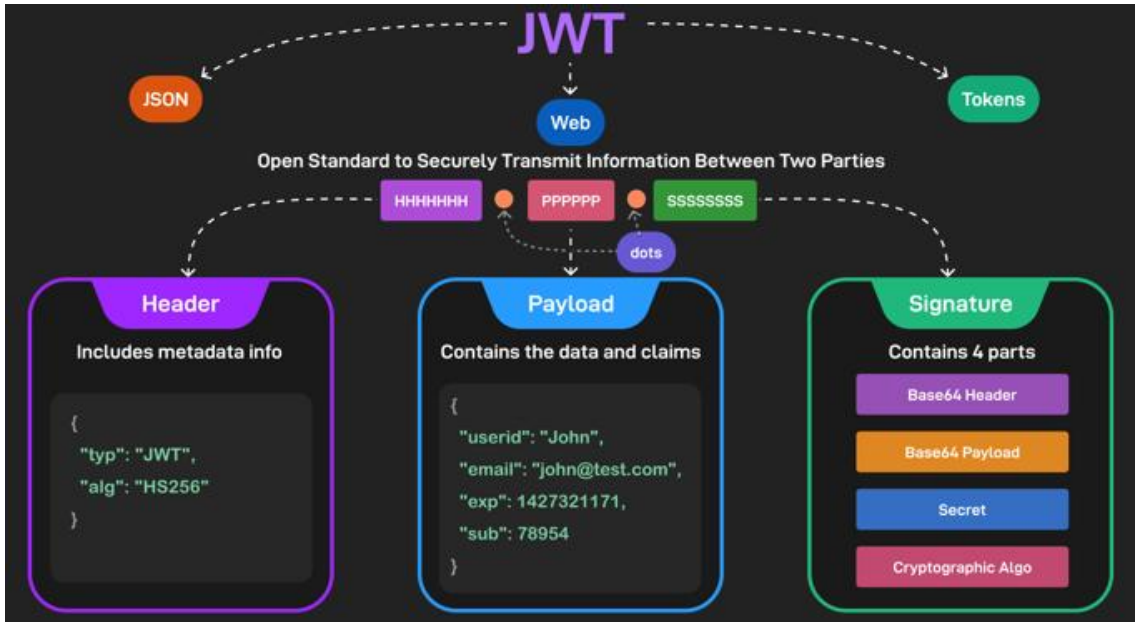


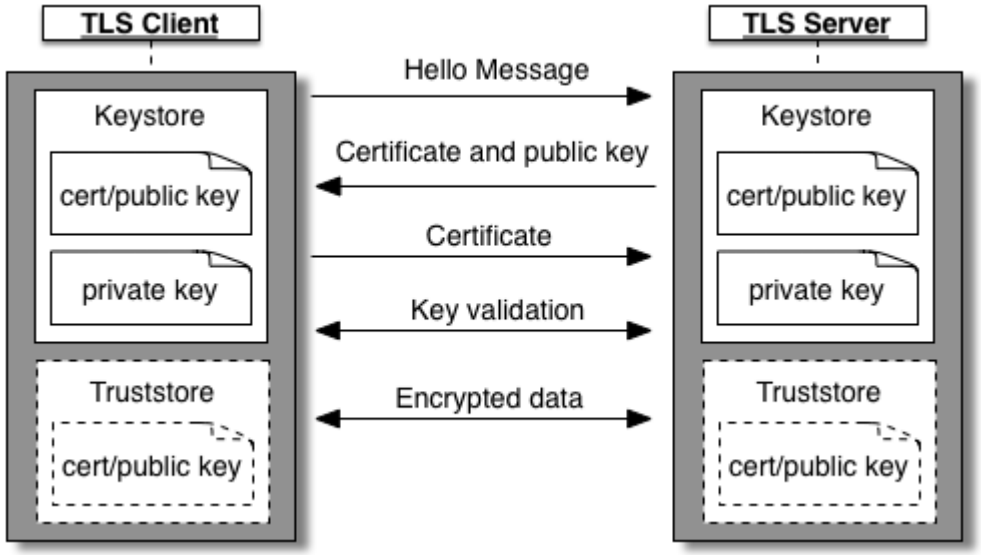
* SAML (Security Assertion Markup Language，安全性聲明標記語言)

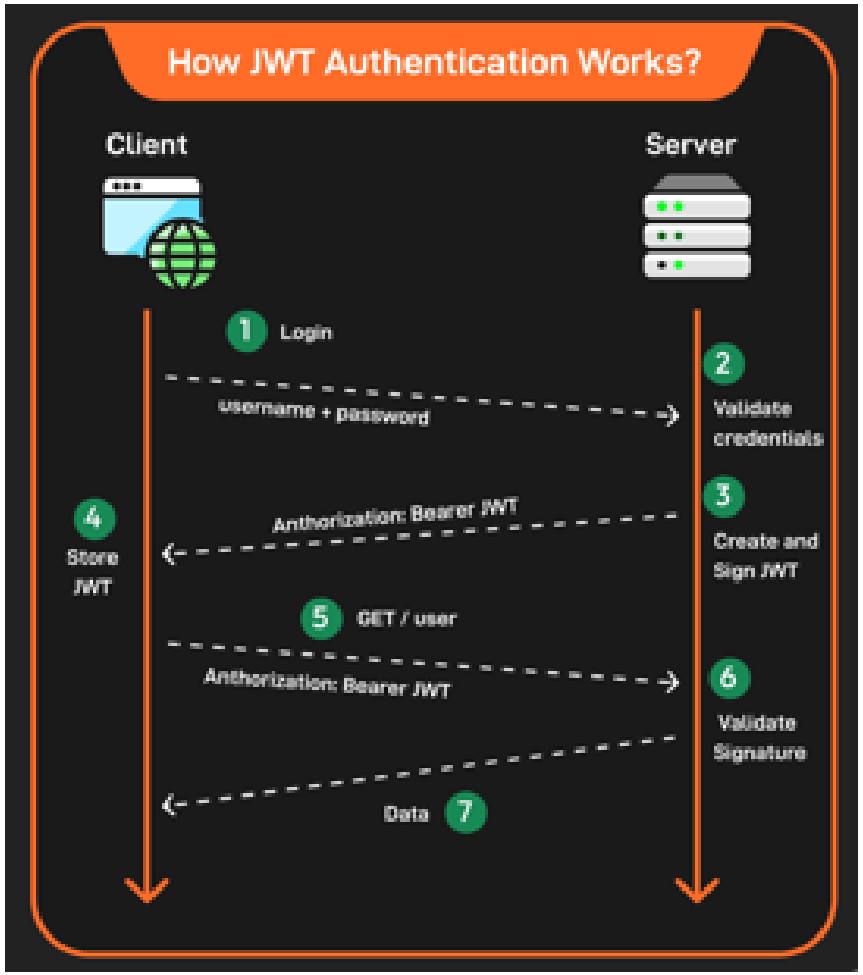
2. 身份管理機制 (Identity Access Management, IAM)



2. 身份管理機制 (Identity Access Management, IAM)







3. 權限控管與授權模型 (RBAC)

基於角色的存取控制 (RBAC) 架構

- Scopes（權限範圍）：應用程式代碼中定義的最細粒度權限（如：讀取、寫入）。
- Role Templates（角色範本）：開發時打包的權限藍圖，定義了可用的 Scopes。
- Roles（角色）：將範本具體化，可在此層級注入「屬性（Attributes）」來實現資料層級的過濾。
- Role Collections（角色集合）：將多個 Role 打包成一個集合，這是直接派發給使用者的最小單位。

平台管理權限（全域與子帳戶）

- Global Account 管理員：擁有最高權限，管理計費、全域設定與子帳戶創建。
- Subaccount 管理員：管理特定子帳戶內的服務綁定、目的地（Destinations）與用戶授權。

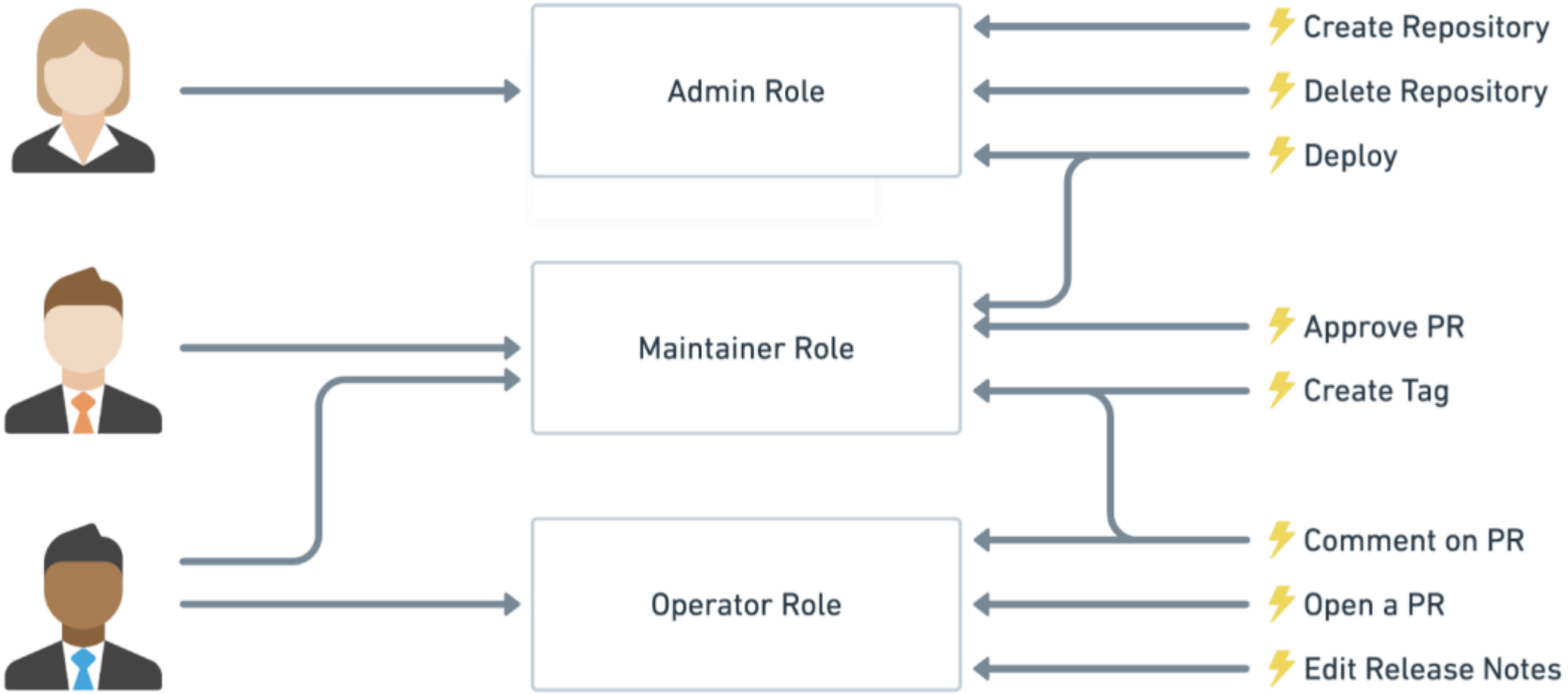
3. 權限控管與授權模型 (RBAC)

SAP BTP 採用基於角色的存取控制 (RBAC) 模型，其架構層次如下，實現了權限的細粒度控管：



- **動態屬性對應 (Attribute Mapping)：企業可將自訂 IdP 中的使用者屬性（例如：部門=財務部，國家=TW）對應到 BTP 的角色集合中。當使用者登入時，系統會動態賦予相應的權限，減少手動維護的負擔。**

3. 權限控管與授權模型 (RBAC)



4.關鍵安全組件解析 (Deep Dive)

這是 BTP 實踐安全架構的四個核心技術齒輪：

A. Identity Provider (IdP)

- 功能：身份提供者。分為預設的 SAP ID Service（供測試/SAP官方用）與 Custom IdP（企業專用）。
- 範例：企業將內部的 OKTA 或 Ping Identity 設定為 Custom IdP，作為所有 BTP 登入的唯一源頭。

B. Trust Configuration

- 功能：信任設定。在 BTP Subaccount 與 IdP 之間建立數位憑證交換（密鑰信任）。
- 範例：就像兩國建交需要簽署外交條約。一旦完成 Trust Configuration，BTP 看到由該 IdP 簽名的數位護照（Token），就會直接放行。

4.關鍵安全組件解析 (Deep Dive)

C. XSUAA (Extended Services for UAA)

- 功能：BTP Cloud Foundry 環境的授權核心（基於 OAuth 2.0 協議），負責核發與驗證 Access Token。
- 範例：電影院的「自動驗票閘門」。XSUAA 檢查使用者手機上的 QR Code（Token），確認這張票是不是真的、有沒有過期、能看 A 廳還是 B 廳。

D. Role Collection

- 功能：角色集合。將多個細微的 Roles 打包成一個大包包，直接指派給使用者或群組。
- 範例：
  - Developer_Collection 包包裝了：代碼部署權限 + 日誌查看權限 + 服務綁定權限。
  - IT 管理員只需要把這個包包丟給新來的工程師，工程師就立刻獲得所有對應工具的存取權。

5. 安全最佳實踐 (Best Practices)

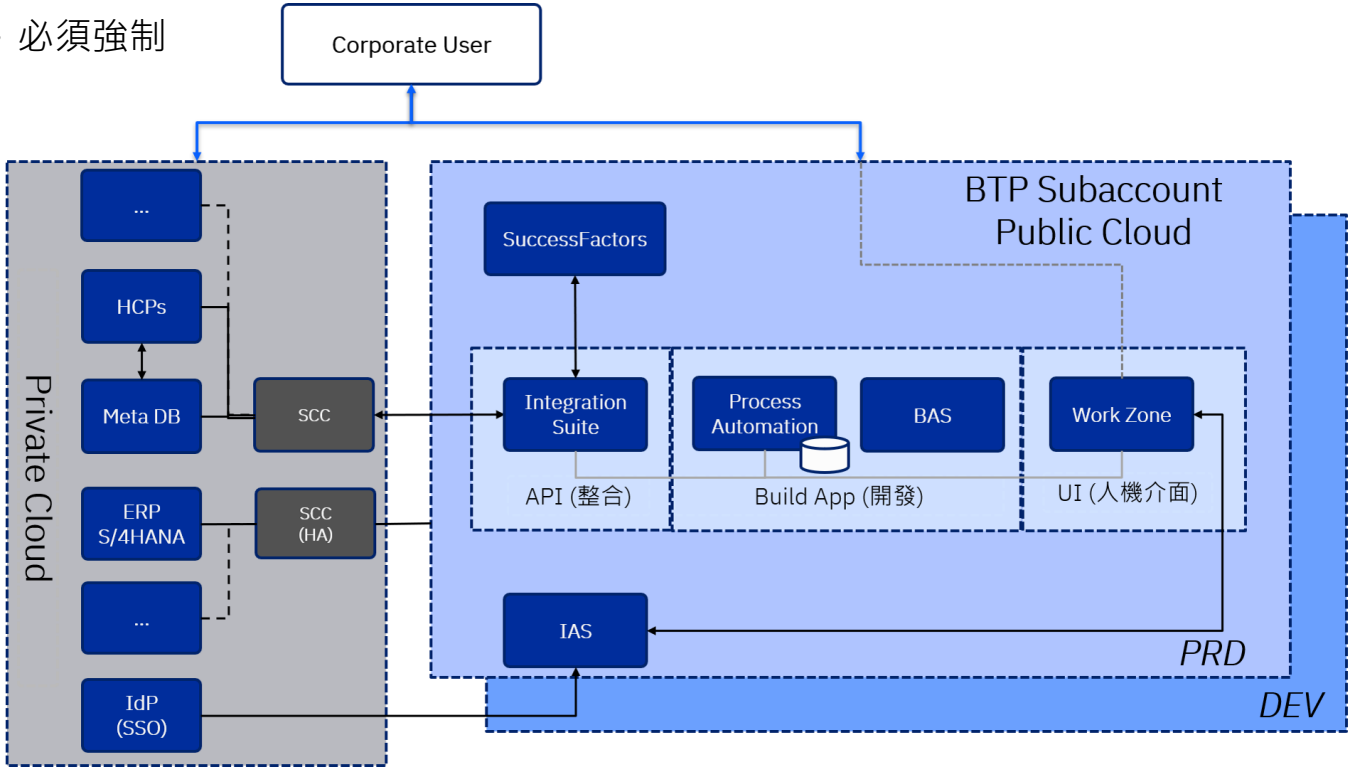
為了落實 SAP BTP 的安全防護，企業在部署時應遵循以下原則：

1.啟用自訂 IAS 租戶：避免直接使用預設的 Default IdP，以便於落實更嚴格的密碼安全與合規原則。

2.強制執行多重驗證 (MFA)：針對所有平台管理員與核心業務使用者，必須強制開啟 MFA 以防範憑證竊取。

3.職責分離 (SoD)：利用 身分安全治理工具或 SAP GRC / IAG，審查混合雲環境下的存取風險與權限衝突。

4.落實環境隔離：全域帳戶下應至少劃分開發 (Dev)、測試 (QAS) 與生產 (Prod) 三個獨立的子帳戶，嚴禁交叉配置權限。



5. 安全最佳實踐 (Best Practices)

身份與存取安全

- 強制啟用 MFA：在 SAP IAS 中對所有平台管理員與關鍵業務帳戶啟用多因素驗證。
- 基於群組的自動化授權：將 BTP Role Collections 對接 IAS 的群組，實現用戶入職/離職時的權限自動同步。

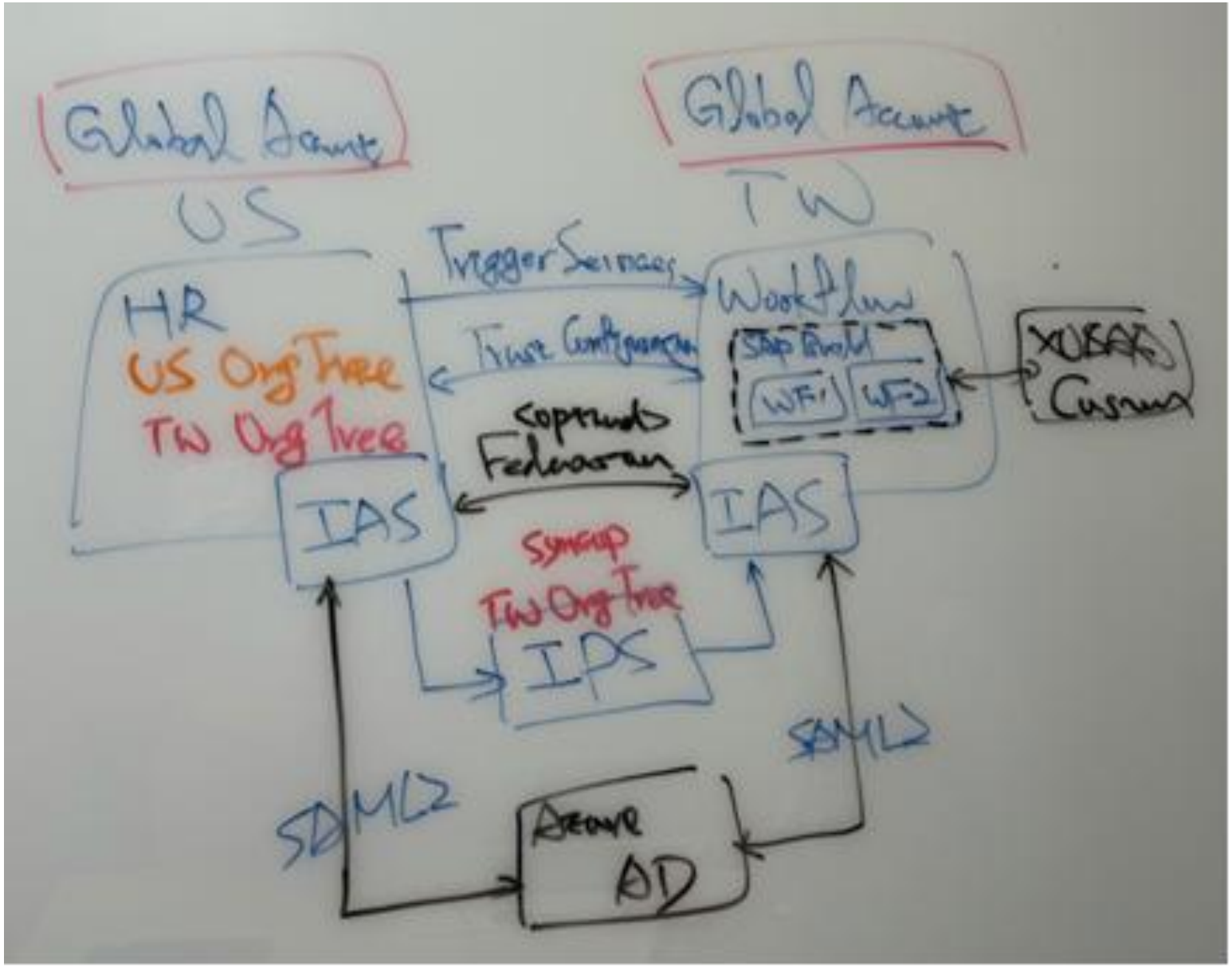
網路與連線安全

- 最小權限原則：Cloud Connector 僅開放特定的 On-Premise 系統與 API 節點，拒絕全網段通聯。
- 使用 Private Link：在支援的雲端環境（如 Azure, AWS）中使用私有鏈接，讓流量不經過公網。

監控與合規

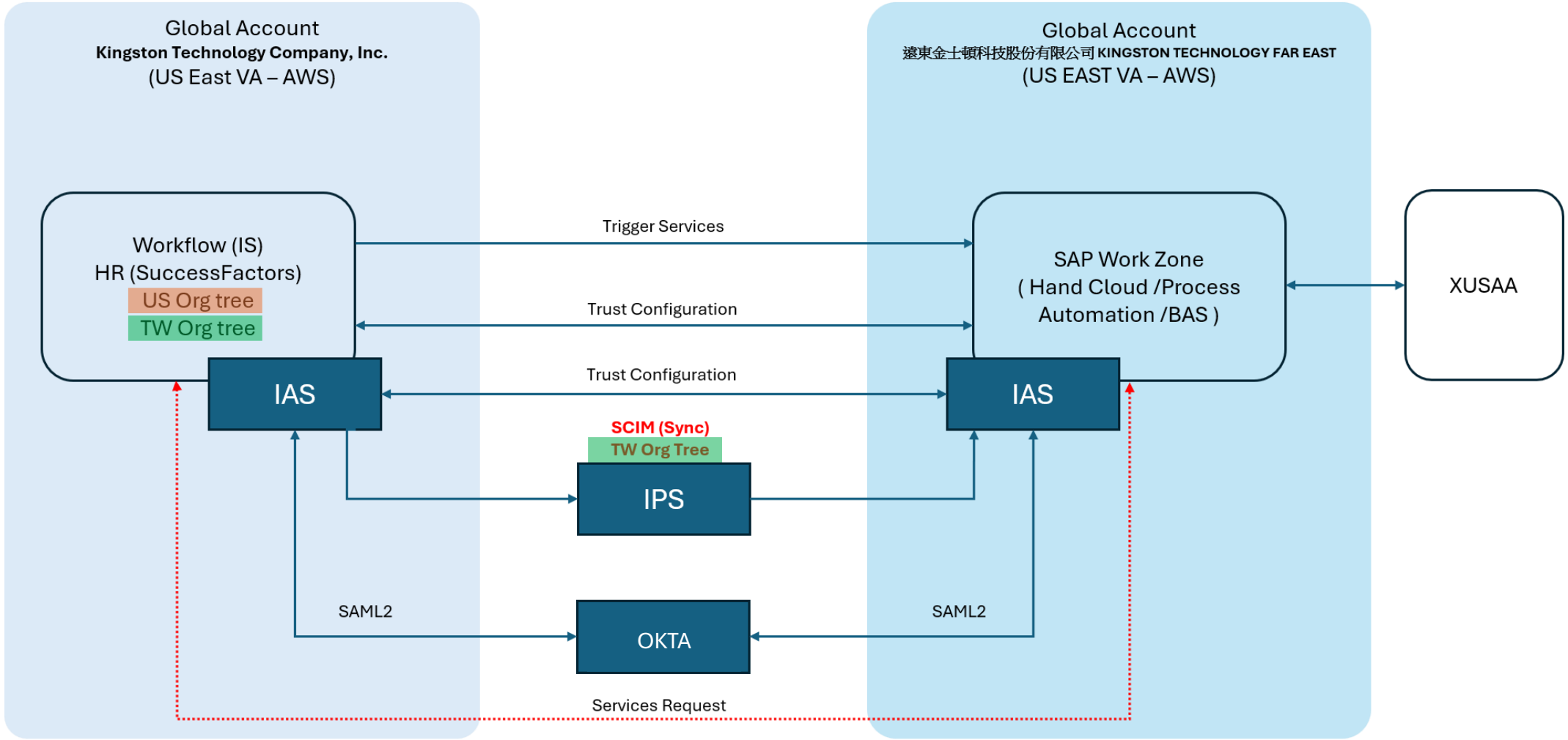
- 集中化日誌管理：將 BTP Audit Log 導出至企業內部的 SIEM（如 Splunk）進行即時監控。
- 定期權限審查：每季審查高權限帳戶，刪除閒置的開發與測試帳戶。

5. 安全最佳實踐 (Best Practices)



5. 安全最佳實踐 (Best Practices)

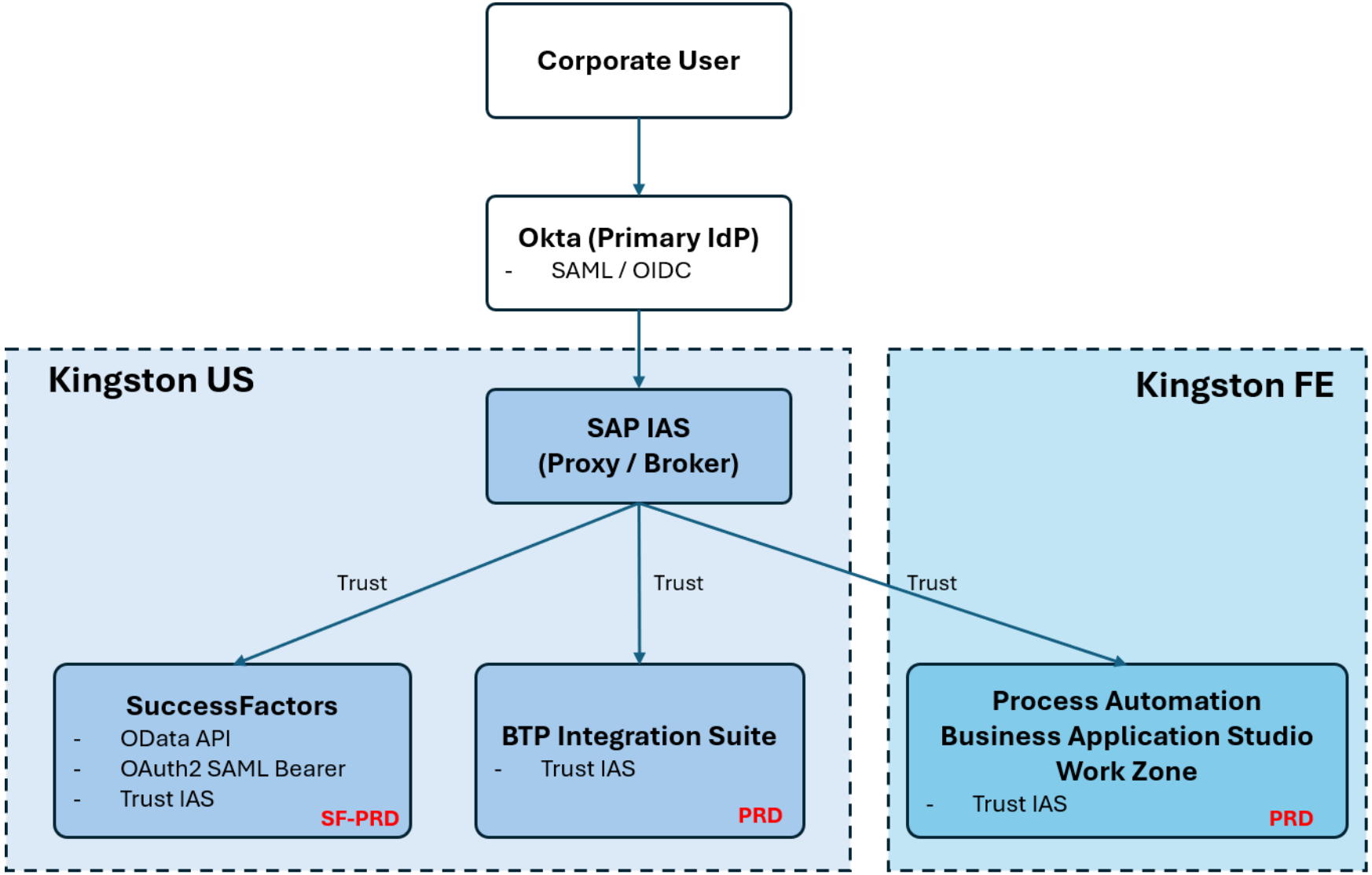
Okta → SAP IAS (Proxy) → SAP BTP (AWS)



https://help.sap.com/docs/btp/sap-business-technology-platform/establish-trust-and-federation-of-custom-identity-providers-for-platform-users

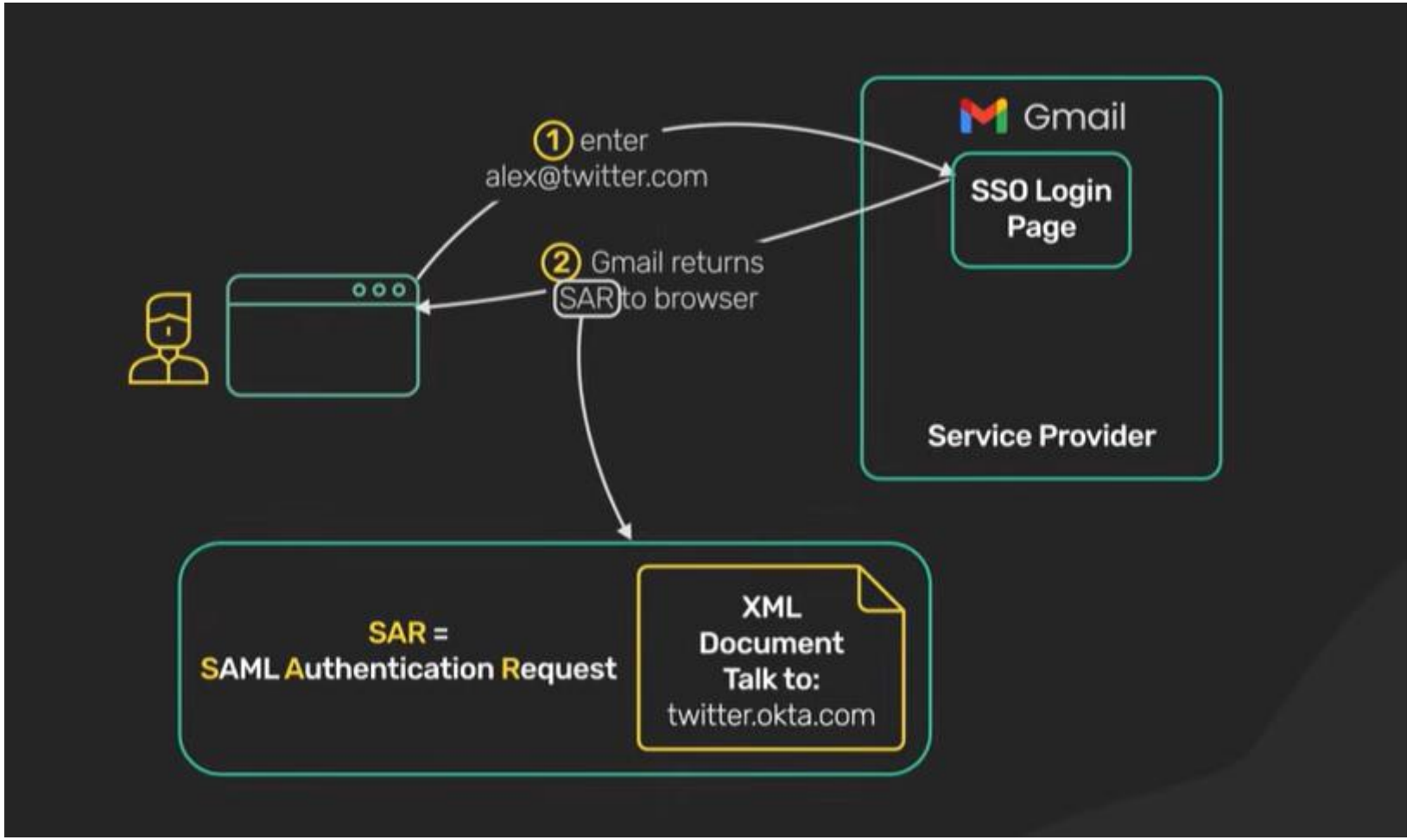
XUSAA - eXtended Services for User Authentication and Authorization

5. 安全最佳實踐 (Best Practices)



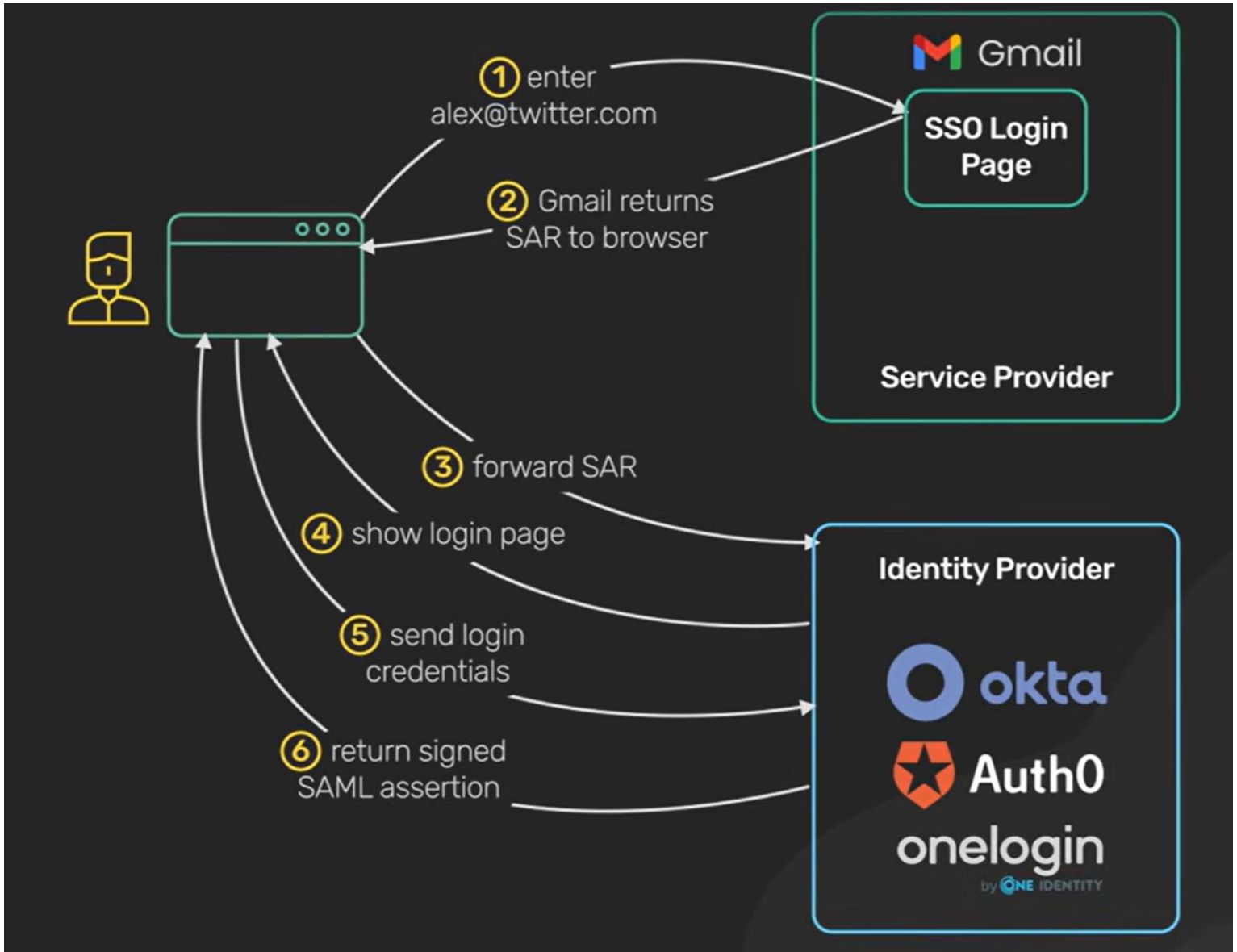
PRD - Subaccount

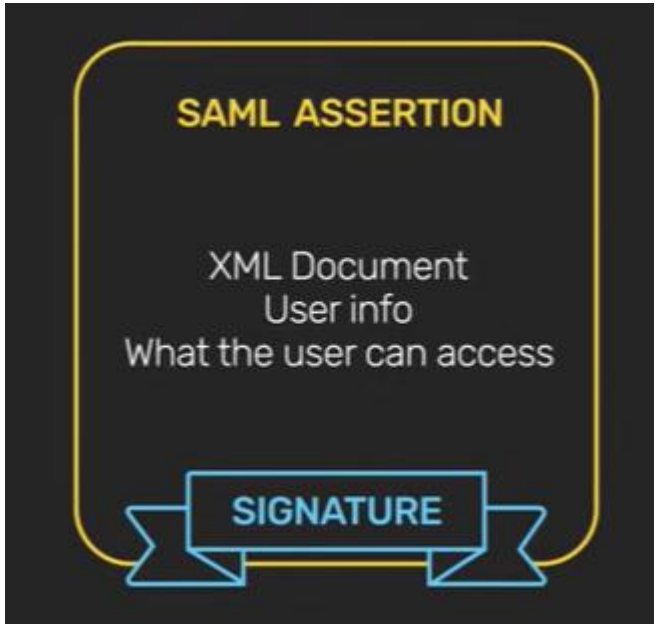
SSO – Process Flow



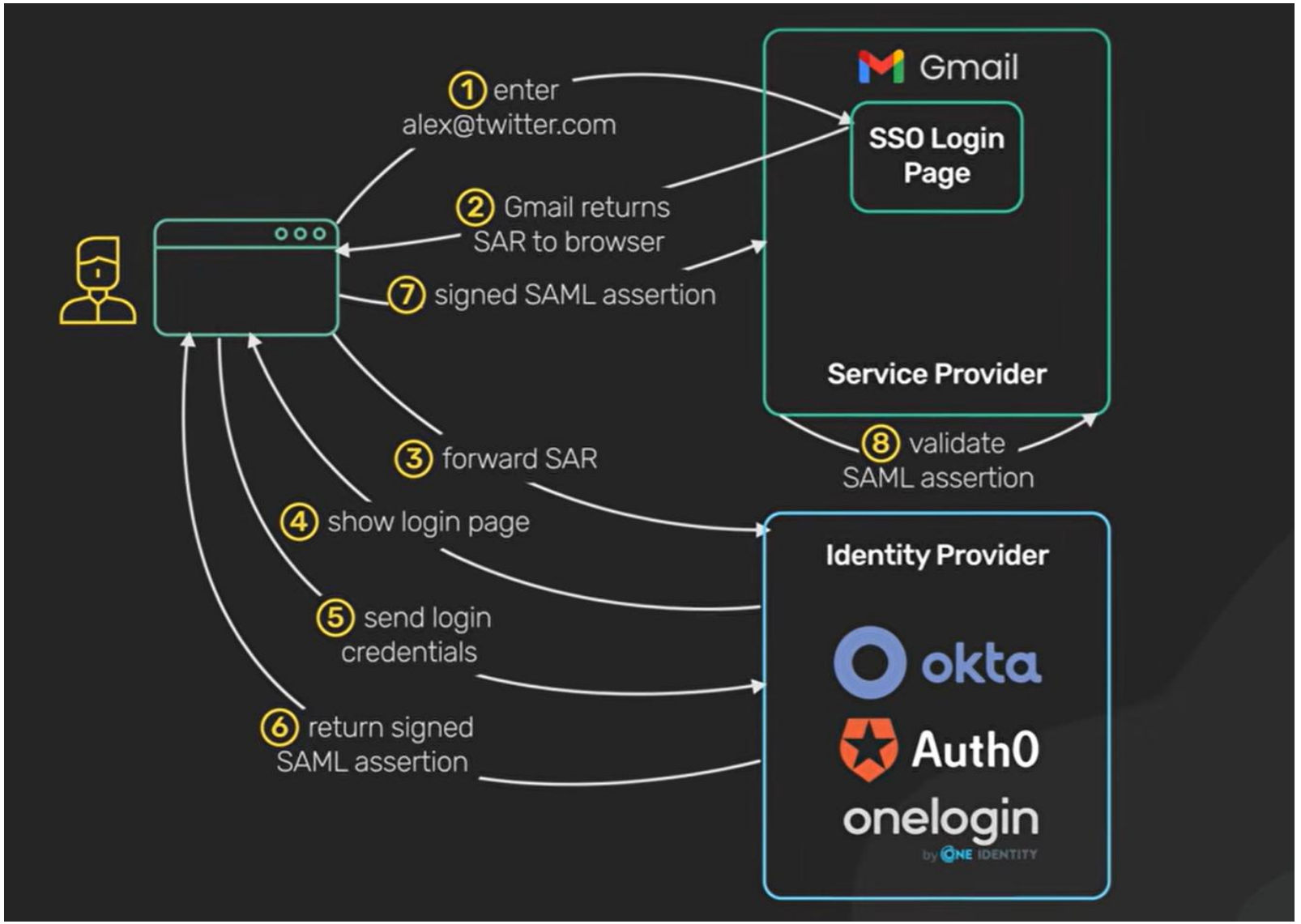
SAR : SamlAssertionRequest - SAML 宣告請求

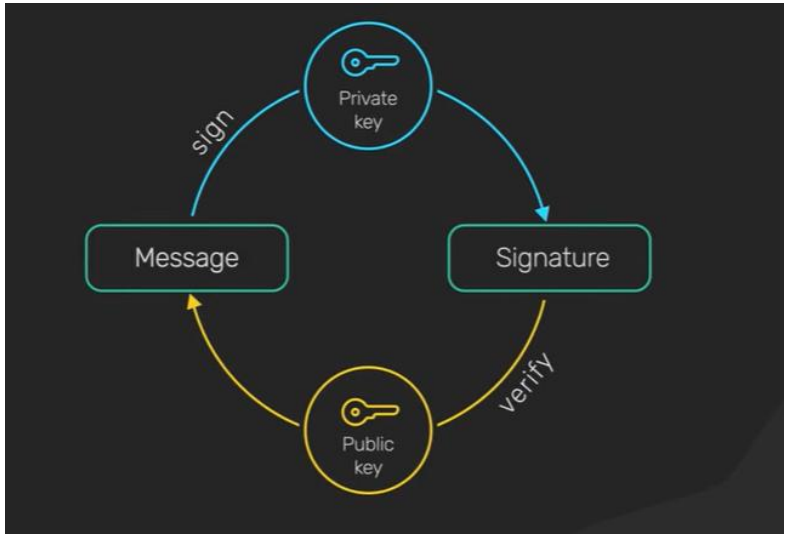
SSO


Gmail
SSO Login Page
Service Provider
1 enter alex@twitter.com
2 Gmail returns SAR to browser
3 forward SAR
4 show login page
5 send login credentials
6 return signed SAML assertion
Identity Provider
okta
Auth0
onelogin
by ONE IDENTITY

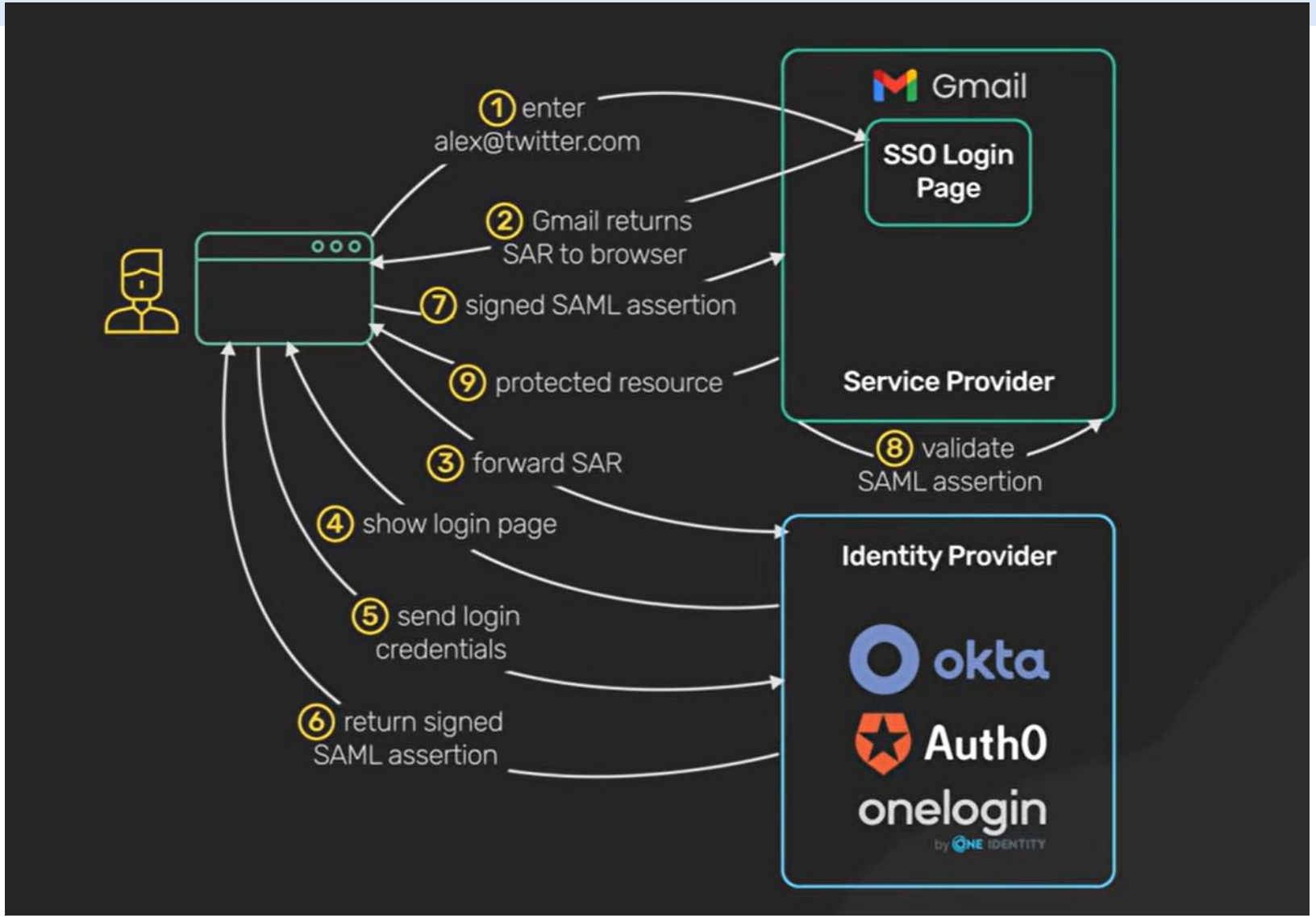

SAML ASSERTION
XML Document
User info
What the user can access
SIGNATURE

SSO


Gmail
SSO Login Page
Service Provider
1 enter alex@twitter.com
2 Gmail returns SAR to browser
7 signed SAML assertion
3 forward SAR
8 validate SAML assertion
4 show login page
5 send login credentials
6 return signed SAML assertion
Identity Provider
okta
Auth0
onelogin
by ONE IDENTITY

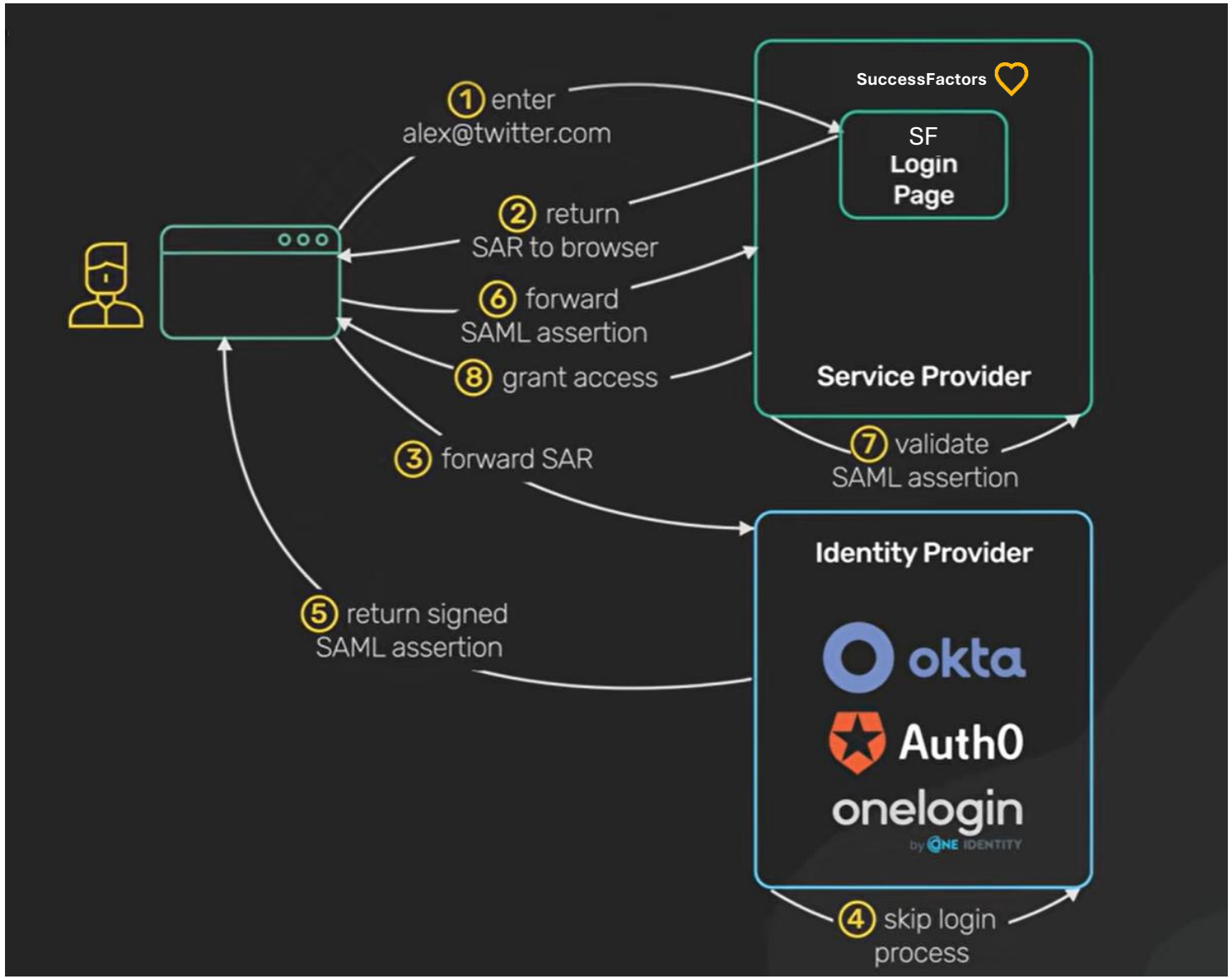

Private key
sign
Message
Signature
verify
Public key

SSO



SAR : SamlAssertionRequest - SAML 宣告請求

SSO


SuccessFactors
SF
Login
Page
Service Provider
1 enter
alex@twitter.com
2 return
SAR to browser
6 forward
SAML assertion
8 grant access
3 forward SAR
7 validate
SAML assertion
Identity Provider
okta
Auth0
onelogin
by ONE IDENTITY
5 return signed
SAML assertion
4 skip login
process

Q&A